

ECR拡張スキャンでSBOMを収集して サプライチェーン攻撃の影響調査を 爆速で終わらせてみた

2026.5.20

池田 晃尚 (@akikii___)





アキキー | 池田 晃尚



株式会社メイツ

- バックエンドエンジニア / SRE

推しサービス



AWS CDK

- AWS CDKへのコントリビュート 8件
- JAWS-UG CDK支部運営



2026/3/19

Trivy

2026/3/23

Checkmarx KICS

2026/3/24

LiteLLM / Telnyx

2026/3/31

axios

2026/4/22

Bitwarden CLI

2026/5/11

TanStack / Mistral AI / UiPath

2026/3/19

Trivy

2026/3/23

Checkmarx KICS

2026/3/24

LiteLLM / Telnyx

2026/3/31

axios

2026/4/22

Bitwarden CLI

2026/5/11

TanStack / Mistral AI / UiPath

→ たくさんのツールが**サプライチェーン攻撃による侵害**を受けています！

ソフトウェアサプライチェーン攻撃とは

ソフトウェアが依存するライブラリやツールに悪意あるコードを混入し、取り込んだプロダクトを間接的に侵害する攻撃手法

ソフトウェアサプライチェーン攻撃とは

ソフトウェアが依存するライブラリやツールに**悪意あるコードを混入**し、取り込んだプロダクトを**間接的に侵害**する攻撃手法

2026/3/31 - npmパッケージ「axios」の侵害

メンテナーアカウントの乗っ取りにより悪意あるバージョンが公開されました。

インストールするだけでRATが展開、**ローカルのクレデンシャル・APIキーが外部に送信**されました。

ソフトウェアサプライチェーン攻撃とは

ソフトウェアが依存するライブラリやツールに**悪意あるコードを混入**し、取り込んだプロダクトを**間接的に侵害**する攻撃手法

2026/3/31 - npmパッケージ「axios」の侵害

メンテナーアカウントの乗っ取りにより悪意あるバージョンが公開されました。

インストールするだけでRATが展開、**ローカルのクレデンシャル・APIキーが外部に送信**されました。

→ **プロダクトに影響がないか**迅速に調査する必要がある

ソフトウェアサプライチェーン攻撃とは

ソフトウェアが依存するライブラリやツールに**悪意あるコードを混入**し、取り込んだプロダクトを**間接的に侵害**する攻撃手法

2026/3/31 - npm

SBOMを利用してコンテナイメージへの影響範囲を一瞬で特定する方法を紹介します！

メンテナアカウントの乗っ取りにより悪意あるバージョンが公開されました。

インストールするだけでRATが展開、**ローカルのクレデンシャル・APIキーが外部に送信**されました。

→ **プロダクトに影響がないか**迅速に調査する必要がある

SBOM ?

SBOM (Software Bill of Materials) とは

ソフトウェアに含まれているOSやパッケージの部品表

どのコンテナでどのパッケージが使われているかがわかる

パッケージ名、バージョン、パッケージURLなど...

```
{
  "bomFormat": "CycloneDX",
  "specVersion": "1.4",
  "version": 1,
  "metadata": {
    "timestamp": "2026-05-18T08:29:10Z",
    "component": {
      "type": "operating-system",
      "name": "AMAZON_LINUX_2023",
      "version": "27.4.0"
```

SBOM (Software Bill of Materials) とは

ソフトウェアに含まれているOSやパッケージの部品表

どのコンテナでどのパッケージが使われているかがわかる

パッケージ名、バージョン、パッケージURLなど...

ECR拡張スキャンを利用すると
SBOMをエクスポートできる！

```
{  
  "bomFormat": "CycloneDX",  
  "specVersion": "1.4",  
  "version": 1,  
  "metadata": {  
    "timestamp": "2026-05-18T08:29:10Z",  
    "component": {  
      "type": "operating-system",  
      "name": "AMAZON_LINUX_2023",  
      "version": "27.4.0"
```

ECR拡張スキャン？

ECRイメージスキャン（拡張スキャン）とは？

ECRリポジトリに登録されたコンテナイメージをセキュリティスキャンするAmazon Inspectorの機能（ECRに統合されている）

ECRイメージスキャン（拡張スキャン）とは？

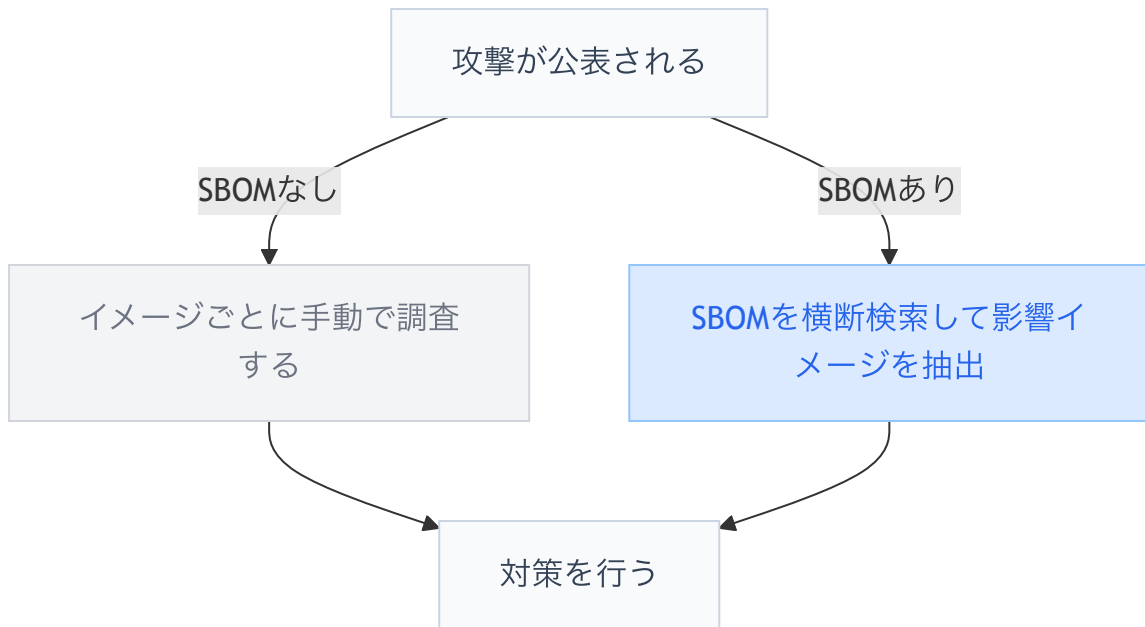
ECRリポジトリに登録された**コンテナイメージをセキュリティスキャン**するAmazon Inspectorの機能（ECRに統合されている）

- OS・パッケージ/ライブラリの脆弱性を検出
- 脆弱性DBにCVEが追加されるとスキャン（継続スキャンの場合）
- コンテナイメージの **SBOM をエクスポート** できる

※ ECRベーシックスキャン、プッシュスキャンはSBOMエクスポート非対応

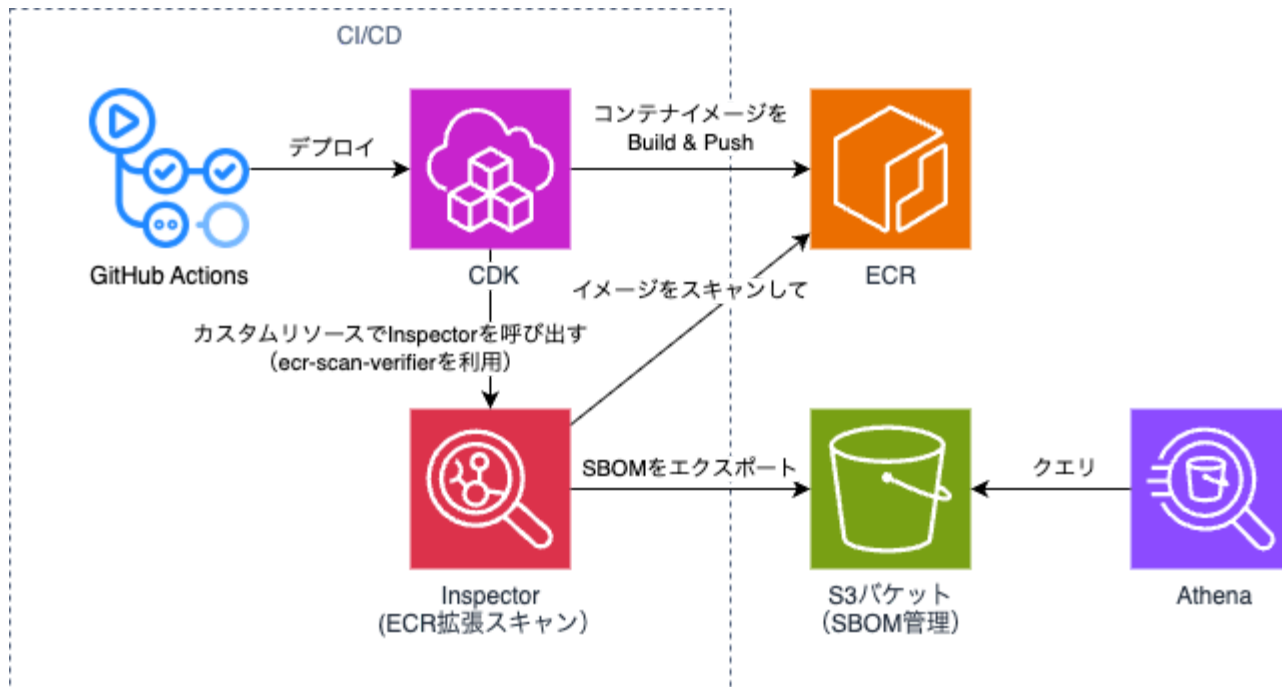
サプライチェーン攻撃の影響範囲を調査する

サプライチェーン攻撃の影響範囲調査（例）



アーキテクチャ

CI/CDで拡張スキンのAPIを呼び出してSBOMをエクスポート



影響調査デモ

AthenaでSBOMを検索して影響調査を行う



まとめ

SBOMを横断で検索する仕組みを作ると
サプライチェーン攻撃の影響調査が爆速で
終わる！！！！

宣传

AWS CDK Conference Japan 2026

7.18 (土)

開催決定！

JAWS-UG CDK支部 主催

詳細は近日公開予定



Call for Proposal

登壇者募集中！

(5/31 23:59まで)



株式会社メイツ

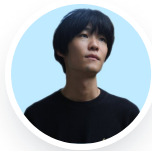
Mates Inc.

AWS Summit Japan 2026

2026.6.25 (木) - 26 (金) 幕張メッセ

SPEAKER ANNOUNCEMENT

弊社チーフエンジニアが AWS Summit Japan に登壇します



SPEAKER

後藤 健太

— AWS DevTools Hero

株式会社メイツ / Chief Engineer

DEV352

BREAKOUT SESSION

2026.6.26 (金) 13:40 - 14:10 • 幕張メッセ Hall 4 / Room 11

aws
HEROES

AWS SUMMIT JAPAN 2026
DEV352

laC コードを資産へ：
AWS CDK 社内ライブラリと横断展開

後藤 健太

AWS DevTools Hero
株式会社メイツ Chief Engineer

教育を、 アップデートする。

教育とテクノロジーを融合させ、
教育が永続的に進化する仕組みを創る。

リードエンジニア（バックエンド/フロントエンド/SRE）

積極採用中



株式会社メイツ
Mates Inc.



カジュアル面談はこちら

Thank You!

＼ ご清聴ありがとうございました！ ／

